

HiveForce Labs

# THREAT ADVISORY



## ATTACK REPORT

### **BlackByte Ransomware Exploits VMware Flaw and Beyond**

Date of Publication

August 30, 2024

Admiralty Code

A1

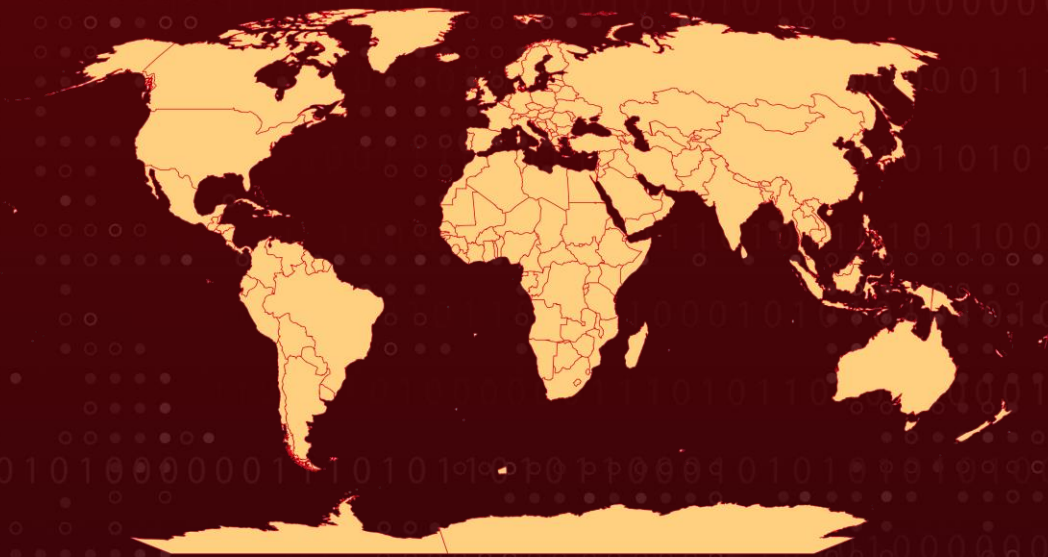
TA Number

TA2024336

# Summary

**First Seen:** July 2021  
**Malware:** BlackByte Ransomware  
**Targeted Region:** Worldwide  
**Targeted Industries:** Manufacturing, Construction, Transportation, Professional Services, Agriculture, Education, Technology, Government  
**Affected Product:** VMware ESXi hypervisors  
**Attack:** BlackByte, a ransomware-as-a-service (RaaS) group believed to have originated from the infamous Conti ransomware, first appeared in 2021. The group rapidly gained notoriety for exploiting security vulnerabilities, including the recently patched CVE-2024-37085, which affects VMware ESXi hypervisors.

## 🗡️ Attack Regions



## ⚙️ CVE

Powered by Bing  
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

| CVE                            | NAME                                            | AFFECTED PRODUCT | ZERO -DAY | CISA KEV | PATCH |
|--------------------------------|-------------------------------------------------|------------------|-----------|----------|-------|
| <a href="#">CVE-2024-37085</a> | VMware ESXi Authentication Bypass Vulnerability | VMware ESXi      | ❌         | ✅        | ✅     |

# Attack Details

#1

BlackByte is a ransomware-as-a-service (RaaS) group that likely evolved from the notorious Conti ransomware group, first emerging in 2021. This group has been observed exploiting a recently patched security vulnerability, tracked as CVE-2024-37085, which affects VMware ESXi hypervisors.

#2

Additionally, BlackByte leverages vulnerable drivers to bypass security defenses and deploys a self-propagating, ransomware encryptor with worm-like capabilities. Over time, BlackByte has refined its ransomware binary, developing versions in Go, .NET, C++, or a combination of these languages.

#3

In recent attacks, the group's tactics involve gaining initial access using valid credentials, often obtained through brute-forcing VPN interfaces. Once inside, they escalate privileges, frequently targeting Domain Admin-level accounts to further infiltrate the victim's network.

#4

BlackByte's attack chain includes reconnaissance and enumeration, using protocols like SMB and RDP. The group is also known for tampering with security configurations, including uninstalling EDR from critical systems and altering essential passwords. Before executing the ransomware, they typically exfiltrate data using tools like their custom ExByte tool.

#5

A notable aspect of BlackByte's tactics is their use of the Bring Your Own Vulnerable Driver (BYOVD) technique, where they drop vulnerable drivers to complicate detection and removal. Encrypted files across all victims are rewritten with the file extension "blackbytent\_h."

## Recommendations



**Harden and Patch VMware ESXi Host:** Harden and patch ESXi hosts to minimize their attack surface. Ensure that all newly discovered vulnerabilities specifically CVE-2024-37085 are patched promptly to protect these critical systems from exploitation.



**Audit and Strengthen VPN Configurations:** Regularly audit your VPN configurations to ensure that outdated or legacy VPN policies are removed. Any authentication attempts that do not match current VPN policies should be automatically denied. Limit VPN access to essential network segments and services only. This approach minimizes the exposure of critical assets, such as Domain Controllers, reducing the attack surface.



**Enhance Authentication Security:** Where possible, limit or disable the use of NTLM (NT LAN Manager) and enforce more secure authentication methods like Kerberos. Implement rate limiting on authentication attempts and failures for both public-facing and internal interfaces to prevent automated scanning and brute-force attacks.



## Potential MITRE ATT&CK TTPs

|                                                      |                                                   |                                                     |                                                        |
|------------------------------------------------------|---------------------------------------------------|-----------------------------------------------------|--------------------------------------------------------|
| <b><u>TA0042</u></b><br>Resource Development         | <b><u>TA0001</u></b><br>Initial Access            | <b><u>TA0002</u></b><br>Execution                   | <b><u>TA0003</u></b><br>Persistence                    |
| <b><u>TA0004</u></b><br>Privilege Escalation         | <b><u>TA0005</u></b><br>Defense Evasion           | <b><u>TA0007</u></b><br>Discovery                   | <b><u>TA0008</u></b><br>Lateral Movement               |
| <b><u>TA0010</u></b><br>Exfiltration                 | <b><u>TA0040</u></b><br>Impact                    | <b><u>T1078.002</u></b><br>Domain Accounts          | <b><u>T1078.003</u></b><br>Local Accounts              |
| <b><u>T1078</u></b><br>Valid Accounts                | <b><u>T1018</u></b><br>Remote System Discovery    | <b><u>T1083</u></b><br>File and Directory Discovery | <b><u>T1136</u></b><br>Create Account                  |
| <b><u>T1136.002</u></b><br>Domain Account            | <b><u>T1204</u></b><br>User Execution             | <b><u>T1569.002</u></b><br>Service Execution        | <b><u>T1543</u></b><br>Create or Modify System Process |
| <b><u>T1484.001</u></b><br>Group Policy Modification | <b><u>T1484</u></b><br>Domain Policy Modification | <b><u>T1098</u></b><br>Account Manipulation         | <b><u>T1021.002</u></b><br>SMB/Windows Admin Shares    |

|                                                    |                                                        |                                                         |                                                    |
|----------------------------------------------------|--------------------------------------------------------|---------------------------------------------------------|----------------------------------------------------|
| <b><u>T1021.001</u></b><br>Remote Desktop Protocol | <b><u>T1210</u></b><br>Exploitation of Remote Services | <b><u>T1608</u></b><br>Stage Capabilities               | <b><u>T1562.001</u></b><br>Disable or Modify Tools |
| <b><u>T1112</u></b><br>Modify Registry             | <b><u>T1070.004</u></b><br>File Deletion               | <b><u>T1211</u></b><br>Exploitation for Defense Evasion | <b><u>T1529</u></b><br>System Shutdown/Reboot      |
| <b><u>T1486</u></b><br>Data Encrypted for Impact   |                                                        |                                                         |                                                    |

## ✂ Indicators of Compromise (IOCs)

| TYPE               | VALUE                                                                                                                                                                                                                                                                           |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>SHA256</b>      | 01aa278b07b58dc46c84bd0b1b5c8e9ee4e62ea0bf7a695862444af32e87f1fd,<br>0296e2ce999e67c76352613a718e11516fe1b0efc3ffdb8918fc999dd76a73a5,<br>543991ca8d1c65113dff039b85ae3f9a87f503daec30f46929fd454bc57e5a91,<br>31f4cfb4c71da44120752721103a16512444c13c2ac2d857a7e6f13cb679b427 |
| <b>File Name</b>   | RtCore64.sys,<br>DBUtil_2_3.sys,<br>zamguard64.sys,<br>gdrv.sys                                                                                                                                                                                                                 |
| <b>TOR Address</b> | tj3ty2q5jm5au3bmd2embtjscd3qjt7nfio2o7cr6moyy5kgil5pieqd[.]onion                                                                                                                                                                                                                |

## ✂ Patch Link

<https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/24505>

## ✂ Recent Breaches

<https://www.modernauto.com/>

<https://cityofnewburgh-ny.gov/>



## References

<https://unit42.paloaltonetworks.com/large-scale-cloud-extortion-operation/>

<https://github.com/SpiderLabs/BlackByteDecryptor>

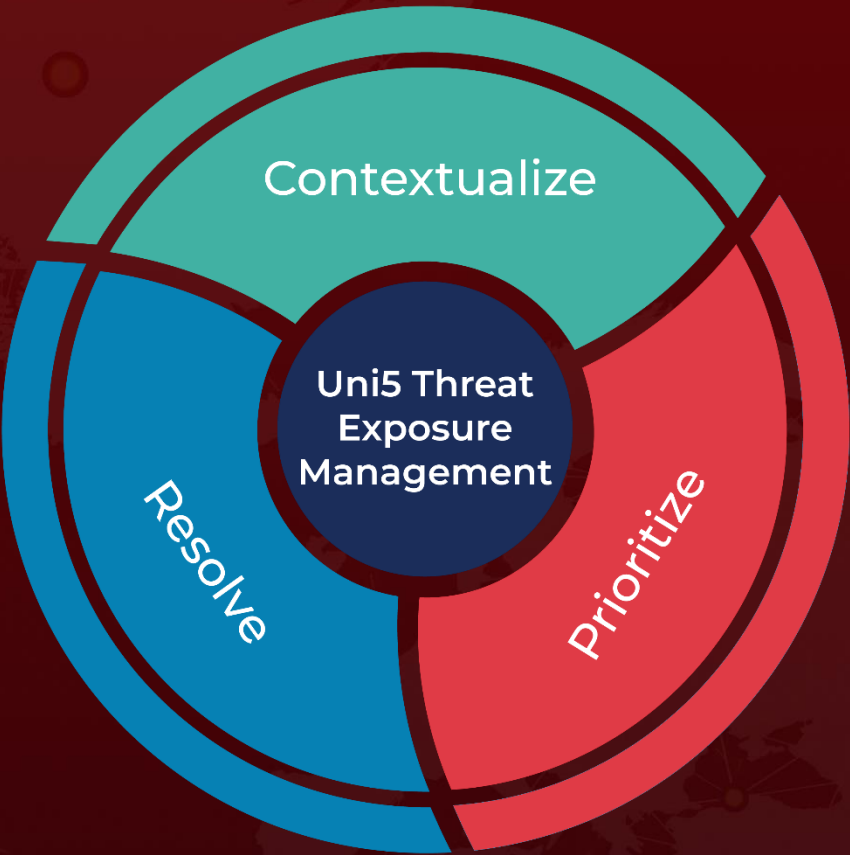
<https://hivepro.com/threat-advisory/blackbyte-uses-a-new-attack-technique-to-target-vulnerable-windows-drivers/>

<https://hivepro.com/threat-advisory/vmware-esxis-fatal-flaw-cve-2024-37085-opens-doors-for-ransomware-havoc/>

# What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

August 30, 2024 • 7:00 AM

© 2024 All Rights are Reserved by HivePro



More at [www.hivepro.com](http://www.hivepro.com)